Customer Data Security

How Urban Steam protects customer information, and what we are strengthening next

Prepared for	In response to	Date
ACS Group	**App Review, 20 October 2026 — point 7**	**21 October 2026**

In short. Urban Steam runs on a dedicated private server that only our team can reach. Everything a customer's phone sends — their name, address, order and wallet balance — travels encrypted and is stored on that one server. Customers never create a password, so there is no password to steal: they sign in with a one-time code sent to their mobile. Card and UPI payments are taken entirely inside Razorpay, a PCI-DSS Level 1 certified gateway. The admin panel is limited to named staff accounts with hashed passwords and role-based access.

The sections below set out precisely what is in place today. Section 8 matters just as much: it lists what we are tightening next, with dates. We would rather give you an accurate picture than a comfortable one.

1 Where the data is kept

- **A dedicated private server**, not shared hosting. The Urban Steam application and its database run on one machine under ACS Group's control, with no other tenants on it.
- **The database is not published to the internet.** It accepts connections only from the application running on the same machine, so there is no database address for an outsider to connect to.
- **A firewall allows only what is needed** — secure web traffic and administrative access. Every other port is refused.
- **Administrative access to the server is by cryptographic key only.** Password logins to the server are switched off entirely, so a guessed or leaked password cannot be used to get in.
- **Repeated failed logins are blocked automatically.** A monitoring service watches authentication attempts and blocks the source address after a small number of failures.
- **Application secrets are kept out of the code and off the apps.** Database credentials, payment keys and SMS credentials live in a single file on the server, readable only by the account that runs the application.

2 How the data travels

- Every request from the Customer app, the Captain app and the admin panel is sent over **HTTPS (TLS)** to **acsgroup.cloud**. Nothing travels in readable form, including over public Wi-Fi.

- The apps talk to **one destination only** — our own server. There are no advertising or analytics components quietly collecting customer data in the background.

3 Who can sign in, and how

Customers

- Sign-in is by **mobile number and a one-time passcode (OTP)** sent by SMS.
- **No customer password exists anywhere in the system.** There is nothing to reuse from another breached website, nothing to guess, and nothing for us to lose.
- A passcode is valid for **10 minutes**, may be attempted at most **5 times**, and is held in the server's working memory only — it is never written to the database or to a log file.
- Customers who prefer it can use **Google Sign-In**, or **Apple Sign-In** on iPhone. Those sign-ins are verified by our server directly with Google or Apple.

Captains (delivery partners)

- The same one-time passcode sign-in.
- A Captain cannot take any work until an administrator has **reviewed and approved their KYC documents** — identity proof, driving licence and bank details.

Administrators

- Staff sign in to the admin panel with a username and password. Passwords are stored as **bcrypt hashes**, salted individually. The password itself is never stored and cannot be read back out of the database, by us or by anyone else.
- Two roles, with different reach: **Admin** (full access) and **Store Manager**, whose view is limited to orders for their own hub's service area.
- Accounts are created for named individuals, so activity is attributable rather than shared.

4 The specific records you asked about

RECORD	WHERE IT IS HELD	HOW IT IS PROTECTED
Customer information (name, mobile, email)	The Urban Steam database on the private server.	Encrypted in transit; no public database access; visible to staff in the admin panel and, for a single job, to the assigned Captain.
Login credentials	Customers and Captains: **none stored**. Staff: bcrypt password hashes.	One-time codes live in memory for 10 minutes and are limited to 5 attempts. A stolen copy of the database would contain no usable customer password, because none exists.
Order details	One record per order, holding the garments, amounts, slot and every status change with its timestamp.	Encrypted in transit; each status change is recorded with the time it happened, so an order's history can always be reconstructed.

RECORD	WHERE IT IS HELD	HOW IT IS PROTECTED
Addresses	On the customer's profile, and copied onto the order being collected.	Released to a Captain only for the order assigned to them, and only while that order is active in their list.
Wallet balances	On the customer's record, maintained by the server.	Every movement — a top-up, an order payment, a refund, an administrative adjustment — writes an audit entry recording who made it, when, why, and the balance before and after.
Transaction records	The wallet audit trail, plus the payment reference held on each order.	Entries are added as history rather than overwritten, so the trail can be reviewed in the admin panel at any time.

5 Payments

- Card and UPI payments are taken by **Razorpay**, which holds **PCI-DSS Level 1** certification — the highest level defined by the card industry.
- The payment is completed inside Razorpay's own secure checkout. Our server receives only a **payment reference and a digital signature**, which it verifies using a secret key held on the server alone. A tampered or invented payment confirmation fails that check.
- Refunds and wallet credits are issued by an administrator through the panel, and each one is written to the audit trail described above.

6 Keeping the platform current

- We follow security advisories for the web framework, the database and the server's operating system, and apply security updates rather than waiting for a scheduled release.
- As a recent example: in October 2026 a critical vulnerability was disclosed in the web framework Urban Steam is built on. **The vendor's fix was applied within days of publication**, along with a review of the server for any sign of misuse.
- Server credentials and application secrets are rotated when staff or suppliers change, and after any maintenance that required sharing them.

7 Planned maintenance, without surprises

A new control in the admin panel puts **both apps** into a single, clearly worded "we will be right back" screen for the duration of any server work. Customers cannot start a booking the system is in no state to complete, and Captains are not handed a job that cannot be recorded. Nobody is left stranded halfway through an order, and both apps return to normal the moment the switch is turned back.

8 What we are strengthening next

Security is maintained, not finished. These are the items already scheduled, in the order we are taking them.

1. **Signed session tokens on every request.** Each request from an app will carry a signed token that proves, on the server, which account it belongs to. This is the single biggest improvement on the list, and it is already in design. November 2026
2. **Removing the optional saved-card fields from the customer profile.** Checkout only needs to know which *kind* of payment a customer prefers; it has never needed the card number itself, because the payment is completed inside Razorpay. Those fields are being removed from the app, and any values already held will be purged. Next app release
3. **Automated nightly database backups, held off the server**, with a restore tested every quarter so that a recovery is a known procedure rather than an experiment. November 2026
4. **Rate limiting on sign-in and passcode requests**, so that automated attempts against a mobile number are throttled at the application as well as at the firewall. November 2026
5. **Masking identity numbers in the admin panel.** Staff reviewing a Captain's KYC will see only the last four digits of an identity or bank account number, with the full value available only where it is genuinely required. December 2026
6. **An annual independent security review**, with the findings and the fixes shared with you. Q1 2027

Questions, or something that looks wrong

If you or a customer ever see anything that looks like unauthorised access — an unexpected passcode message, an order nobody placed, a wallet balance that does not add up — please tell us straight away at **support@urbansteam.in**. We will acknowledge within one working day and come back to you with what we find.

Prepared by the Urban Steam development team. This document describes the platform as at 21 October 2026, and will be reissued as the items in section 8 are delivered.